

EXECUTIVE REPORT

Course	Offensive Security Operations II
Legacy Code	CIP-A105
Assessment	CTF 2 – Summative Competency Exam
Operation Codename	OPERATION BLACK FORGE
Target	OPFOR-02 (Healthcare OVA)
Student Name	Loveth Adebayo
Registration Number	C11/26/EHIT/17323
Submission Date	22 September 2026
Classification	TRAINING USE ONLY

1. EXECUTIVE SUMMARY

Operation Black Forge was a black-box assessment of the OPFOR-02 appliance, an intentionally vulnerable legacy Linux system. The objective was to identify exposed services, gain a foothold, escalate to root, and produce an evidence-backed remediation report.

Reconnaissance identified two open services: FTP (ProFTPD 1.3.3d) on port 21 and HTTP (Apache 2.2.17) on port 80. Directory brute-forcing uncovered OpenEMR 4.1.0 running on PHP 5.3.3. An unauthenticated SQL injection in validateUser.php was exploited with SQLMap to dump the users table and crack the admin password.

Authenticated access enabled RCE via an unrestricted patient document upload, producing a foothold as apache. Post-exploitation found a SUID-root binary, /usr/bin/healthcheck, vulnerable to PATH hijacking. This yielded SUID-root bash and full root access.

Both mission proofs were captured.

User flag: d41d8cd98f00b204e9800998ecf8427e.

Root flag: eaff25eaa9ffc8b62e3dfbf70e83a7b.

Key risks: end-of-life stack, unauthenticated SQLi in a medical records system, and a SUID misconfiguration allowing any local user to become root. The target was restored to its clean baseline after evidence collection.

2. SCOPE AND RULES OF ENGAGEMENT

Target: OPFOR-02 (Healthcare OVA) at 192.168.56.109 on an isolated Host-Only network.

Attacker: Kali Linux at 192.168.56.105 on the same network segment (vboxnet0, 192.168.56.0/24).

Rules observed:

- Only the authorised target was tested.
 - No external or production systems were accessed.
 - Bridged networking and public exposure were disabled.
 - No denial-of-service or destructive actions were performed.
 - All artifacts were removed after evidence collection.
 - Target restored to the CIP-A105-CTF2-CLEAN-BASELINE snapshot.
-

3. LABORATORY ARCHITECTURE AND METHODOLOGY

Two VirtualBox VMs on an isolated Host-Only network:

Component	Value
Attacker	Kali Linux — 192.168.56.105
Target	OPFOR-02 — 192.168.56.109
Hypervisor	Oracle VirtualBox
Baseline	CIP-A105-CTF2-CLEAN-BASELINE

OVA integrity was verified: MD5 and SHA1 matched the Academy-supplied values.

Methodology followed the ICDDFA Operations Brief and the OWASP WSTG. Phases: preparation, discovery, enumeration, exploit-chain development, initial access, post-exploitation, privilege escalation, remediation, cleanup.

Tools used: nmap, netdiscover, curl, gobuster, sqlmap, john, hashcat, Firefox Developer Tools, custom PHP webshell.

4. ATTACK-SURFACE SUMMARY

Full TCP scan identified:

Port	Service	Version
21	FTP	ProFTPD 1.3.3d
80	HTTP	Apache 2.2.17 (PCLinuxOS 2011)

UDP scan identified only mDNS (5353/udp).

Web enumeration identified the following paths:

- /openemr/ — OpenEMR 4.1.0 on PHP 5.3.3 (primary attack surface)
- /phpMyAdmin/, /gitweb/, /server-status/ — restricted to localhost
- /addon-modules/ — restricted to localhost

- /cgi-bin/test.cgi — Perl diagnostic script (dead end)
Application fingerprint: OpenEMR 4.1.0, Apache 2.2.17, PHP 5.3.3, PCLinuxOS 2011, kernel 2.6.38.8.
-

5. CONFIRMED FINDINGS AND RISK RATINGS

ID	Finding	Severity
1	Unauthenticated SQL injection in OpenEMR validateUser.php	Critical
2	User enumeration via validateUser.php	Medium
3	Unsalted SHA1 password storage	High
4	Unrestricted file upload (Patient Documents)	Critical
5	PHP execution enabled in upload directory	High
6	SUID-root /usr/bin/healthcheck vulnerable to PATH hijack	Critical
7	World-readable /var/backups/shadow	High

Evidence: E-12 through E-26.

6. INITIAL-ACCESS NARRATIVE

Reconnaissance identified only FTP and HTTP. Directory brute-forcing with the DirBuster-2007 medium wordlist uncovered /openemr/, a legacy EMR platform.

Analysis of the login flow revealed an AJAX endpoint, validateUser.php, that accepted a username and returned a hashing-algorithm indicator. A single quote in the u parameter produced a database error revealing the full backend query:

text

```
select password,length(password) as passlength from users where username = 'admin'
```

SQLMap confirmed boolean, error, and time-based SQL injection. The openemr.users table was dumped:

Username	SHA1 Hash	Cracked Password
admin	3863efef9ee2bfbc51ecdca359c6302bed1389e8	ackbar
medical	ab24aed5a7c4ad45615cd7e0da816eea39e4895d	medical

Credentials were used to log into OpenEMR as Administrator.

7. POST-EXPLOITATION AND PRIVILEGE ESCALATION

With authenticated OpenEMR access, a patient record was created and a PHP webshell was uploaded through the Patient Documents module. The upload was stored at `/var/www/html/openemr/sites/default/documents/1/cmd.php` and executed by Apache. Foothold as apache (uid 479) achieved.

Host enumeration identified:

- Hostname: localhost.localdomain
 - Kernel: 2.6.38.8-pclos3.bfs
 - Users: medical (500), almirant (501), apache (479)
 - Readable: `/home/almirant/user.txt`, `/var/backups/shadow`, `/var/backups/passwd`
- SUID enumeration identified `/usr/bin/healthcheck` — mode 6755, root:root. Strings analysis showed the binary calls `system()` with an unqualified command:

text

```
clear ; echo 'System Health Check' ; ifconfig ; fdisk -l ; du -h
```

A PATH hijack was performed by planting a malicious `ifconfig` in `/tmp` and invoking `healthcheck` with `/tmp` prepended to PATH. The resulting binary, `/tmp/rootbash`, was SUID-root:

text

```
-rwsr-xr-x 1 root root /tmp/rootbash
```

Invocation confirmed root:

text

```
uid=479(apache) gid=416(apache) euid=0(root) groups=0(root),416(apache)
```

Root flag read from `/root/root.txt`.

8. MISSION OBJECTIVES AND PROOF OF COMPLETION

Objective	Status
Map attack surface	Complete
Establish initial foothold	Complete
Linux host enumeration	Complete
Achieve highest authorised privilege level	Complete (root)
Document material weaknesses	Complete
Collect mission proofs	Complete
Restore clean baseline	Complete

Mission proofs:

Proof	Value
User flag	d41d8cd98f00b204e9800998ecf8427e
Root flag	eaff25eaa9ffc8b62e3dfebf70e83a7b

Attack chain:

text

Reconnaissance (nmap)

↓

Web enumeration (gobuster → /openemr/)

↓

SQL injection (validateUser.php → sqlmap → dump)

↓

Credential recovery (admin:ackbar)



Authenticated access (OpenEMR dashboard)



File upload RCE (cmd.php → apache foothold)



Post-exploitation (SUID healthcheck identified)



PATH hijack (SUID /tmp/rootbash → root)



Root flag captured

9. REMEDIATION ROADMAP

Immediate (0–7 days):

1. Take OpenEMR offline until upgraded.
2. Remove SUID bit from /usr/bin/healthcheck.
3. Remove /var/backups/shadow and /var/backups/passwd.
4. Rotate all credentials (OpenEMR users, MySQL).
5. Remove any remaining uploaded webshells.
6. Restrict or disable FTP.

Short-term (1–3 months):

1. Upgrade OpenEMR to a supported release.
2. Replace PCLinuxOS 2011 with a supported distribution.
3. Upgrade PHP to 8.x and Apache to 2.4.x.
4. Deploy a WAF.
5. Enforce least privilege for the web user.
6. Implement server-side file upload validation.

Strategic (3–12 months):

1. Establish a formal patch management process.
 2. Deploy centralised logging and alerting.
 3. Implement MFA for administrative access.
 4. Move secrets out of source code.
 5. Run annual third-party penetration tests.
 6. Block dangerous PHP functions in php.ini.
-

10. CONCLUSION AND LESSONS LEARNED

Operation Black Forge achieved full compromise of OPFOR-02 from reconnaissance to root. The chain exploited a legacy application stack, unauthenticated SQL injection, unrestricted file upload, and a SUID PATH-hijack vulnerability.

Lessons:

- Balance network and application enumeration. Stopping at FTP and the decoy page would have missed the actual path.
 - Failed hypotheses (FTP backdoor, Shellshock, mod_proxy, X-Forwarded-For bypass) were documented and abandoned on evidence.
 - Defensive depth is not optional. Any single control — parameterised queries, SUID removal, file-type validation, or backup-file hardening — would have broken the chain.
 - End-of-life software should not remain in production. The stack was over ten years out of support and gave up every layer of the chain.
-

APPENDIX A — OPERATOR ACTIVITY LOG

Submitted as Annex B. Full chronological record of commands, tools, observations, and evidence references, including failed hypotheses.

APPENDIX B — EVIDENCE INDEX

Evidence	Description
E-1	Clean baseline snapshot
E-2	Kali VM IP confirmed
E-3	Netdiscover live hosts
E-4	Nmap service scan
E-5	Nmap all-port scan
E-6	Nmap UDP scan

Evidence	Description
E-7	HTTP root probe
E-8	robots.txt
E-9	Gobuster raft run
E-10	Gobuster — OpenEMR discovered
E-11	OpenEMR endpoint confirmed
E-12	validateUser SQL error
E-13	User enumeration
E-14	SQLMap injection confirmed
E-15	Users table dump
E-16	OpenEMR admin login
E-17	Webshell created
E-18	Patient Documents tab
E-19	Webshell upload success
E-20	RCE confirmed (uid 479)
E-21	Host enumeration
E-22	User flag captured
E-23	Shadow backup leaked
E-24	PATH hijack setup

Evidence	Description
E-25	SUID rootbash created
E-26	Root flag captured
E-27	Cleanup verified
E-28	Clean baseline restored
E-29	Restoration verified

APPENDIX C — RISK REGISTER

ID	Asset	Likelihood	Impact	Severity	Evidence
1	OpenEMR validateUser.php	High	Critical	Critical	E-12, E-14
2	OpenEMR user enumeration	Medium	Low	Medium	E-13
3	OpenEMR password storage	High	High	High	E-15
4	OpenEMR file upload	High	Critical	Critical	E-18, E-19
5	Apache upload directory	High	High	High	E-20
6	SUID healthcheck	High	Critical	Critical	E-22, E-24
7	/var/backups/shadow	Medium	High	High	E-23